Vikas R

192311353

CSE

ITA1409-ETHICAL HACKING

CO2-AT2

Cybersecurity Practical Record – OSINT, GoPhish and Nmap

Below is a report-style answer for all three questions, suitable for a 20 + 20 + 10 mark practical assignment. It includes objectives, commands, procedures, findings, risk analysis, screenshots to capture, and recommendations.

Important: The actual scan results, GoPhish campaign statistics, and screenshots must come from your Kali Linux lab. I will not invent results or claim that a scan or campaign was executed. For Tesla and Nmap, keep testing within permitted scope; use dummy accounts for phishing simulations.

1. OSINT-Based Email Enumeration Using theHarvester (20 Marks)

Aim

To use theHarvester in Kali Linux to collect publicly available email addresses, subdomains, hosts, and IP addresses associated with `tesla.com`, and assess the security risks of information exposure.

Tools required

- Kali Linux
- theHarvester
- Internet connection
- Terminal

Procedure and commands

Step 1: Open the terminal

Open Kali Linux and launch the terminal.

Step 2: Check theHarvester availability

```
theHarvester -h
```

This displays the supported options and data sources.

Step 3: Perform passive OSINT collection

Use a supported public search source:

```
theHarvester -d tesla.com -b duckduckgo
```

If that source is unavailable in your installed version, use another source listed by `theHarvester -h`.

The command requests publicly indexed information associated with the domain. Results depend on the source, current indexing, and tool version.

Step 4: Save the findings

If your installed version supports the output option, save the results in an HTML report:

```
theHarvester -d tesla.com -b duckduckgo -f tesla_osint
```

Check the generated report and the terminal output. Do not assume that every possible email address or subdomain has been discovered.

Findings to record

Use the following table to document the actual results from your authorized lab exercise.

Category	What to record
Email addresses	Publicly indexed addresses, if returned
Subdomains	Discovered public subdomains, if returned
Hosts	Hostnames associated with the domain
IP addresses	Addresses returned by the tool, if available
Data source	Search engine or public source used
Limitations	Missing results, inaccessible sources, or errors

TheHarvester may return few or no results for a particular source. A blank result does not prove that no public information exists.

Categorization of email addresses

For the report, categorize any addresses that are actually discovered by their apparent function. Do not infer an employee's department solely from their name.

Likely role	Common naming pattern (illustrative only)	Potential risk
Support	`support@domain.com`	Fake technical support requests
Sales	`sales@domain.com`	Invoice and business email scams
Human Resources	`hr@domain.com`	Fake recruitment and employee-document scams
Administration	`admin@domain.com`	Impersonation of administrative staff
Technical teams	`it@domain.com`	Fake IT alerts and credential requests

These are examples of role-based naming patterns, not verified Tesla email addresses.

Risk analysis

- Spear-phishing: Public names, roles, and organizational details can make targeted messages appear more credible.
- Credential harvesting: Fraudulent login pages may be used to trick employees into disclosing passwords.
- Impersonation: Attackers may pretend to be support staff, HR employees, or administrators.
- Infrastructure reconnaissance: Public subdomains and IP addresses may reveal the organization's external attack surface.
- Pretext development: Public company information can be misused to create believable but fraudulent scenarios.

TheHarvester results alone do not prove that a system is vulnerable or that an email address is active.

Security recommendations

1. Minimize unnecessary personal contact information published on public websites.
2. Enable multifactor authentication (MFA), preferably phishing-resistant authentication for privileged accounts.
3. Configure SPF, DKIM, and DMARC to help prevent email-domain spoofing.
4. Provide regular phishing and social-engineering awareness training.
5. Use email filtering, malicious-link detection, and attachment scanning.
6. Restrict administrative interfaces and exposed services to authorized networks.
7. Monitor domain and subdomain exposure through periodic authorized OSINT reviews.
8. Establish a simple procedure for reporting suspicious messages.
9. Apply least privilege to employee and administrator accounts.
10. Train support personnel to verify identity before resetting passwords or changing account access.

Screenshots to include

PenTesting 101: Using TheHarvester for OSINT and Reconnaissance

Screenshot 1 – Tool availability

Capture the terminal showing `theHarvester -h` and the available options.

TheHarvester: What is it and how do you use this OSINT tool?

Screenshot 2 – OSINT results

Capture the command and actual results, including any errors or empty-result messages.

Result

TheHarvester can support passive OSINT by collecting publicly indexed email addresses, subdomains, and related host information. The findings help identify information exposure and guide defensive security improvements.

2. Phishing Awareness Simulation Using GoPhish (20 Marks)

Aim

To conduct a controlled phishing-awareness simulation using GoPhish and dummy employee accounts, measure employee interactions, and recommend improvements to security awareness.

Tools required

- Kali Linux or another authorized lab computer
- GoPhish
- Dummy employee email accounts
- An authorized lab email server
- A web browser

Procedure

Step 1: Start GoPhish

Start the GoPhish service according to your installation instructions and open its administration interface.

The default local administration address in many installations is:

```
https://127.0.0.1:3333
```

Use the configured administrator credentials and change any default credentials before using the application.

Step 2: Create dummy employee accounts

Create a small test group using lab-controlled accounts, for example:

Employee ID	Test account	Department
EMP001	employee1@your-lab-domain.test	IT
EMP002	employee2@your-lab-domain.test	HR
EMP003	employee3@your-lab-domain.test	Sales

These are illustrative entries. Use only accounts and mail infrastructure you control.

Step 3: Create an email template

Create a clearly authorized training scenario that does not request real passwords or sensitive information.

Example subject: Cybersecurity Awareness Training

Example email:

Hello Employee,

You are invited to participate in the organization's scheduled cybersecurity awareness exercise. Please open the approved training page to review the security guidelines.

Thank you,
IT Security Awareness Team

Use a lab-controlled landing page that records test interactions without collecting actual credentials.

Step 4: Configure the sending profile

In GoPhish, configure the sending profile using the authorized lab SMTP server, sender address, and connection details. Verify delivery with a test message before launching the campaign.

Step 5: Create and launch the campaign

1. Select the email template.
2. Select the dummy employee group.
3. Configure the approved training landing page.
4. Set the sending profile.
5. Start the campaign within the agreed lab schedule.
6. Monitor delivery, opens, clicks, and reporting events.

Step 6: Monitor campaign statistics

Record the actual numbers displayed by GoPhish. Use the following example only to understand the calculations.

Metric	Example count
Emails sent	20
Emails delivered	18
Emails opened	12

Link clicks	6

The values above are hypothetical, not results from a real campaign.

Calculating the metrics

$$\text{Delivery rate} = \frac{\text{Delivered}}{\text{Sent}}\times100$$
$$\text{Open rate} = \frac{\text{Unique opens}}{\text{Delivered}}\times100$$
$$\text{Click rate} = \frac{\text{Unique clicks}}{\text{Delivered}}\times100$$

For the illustrative data:

- Delivery rate = $18/20 \times 100 = 90\%$
- Open rate = $12/18 \times 100 \approx 66.7\%$
- Click rate = $6/18 \times 100 \approx 33.3\%$

Email opens may be undercounted or overcounted because of image blocking, privacy features, and automated email scanners. Clicks may also be triggered by automated security systems, so interpret the results carefully.

Analysis and recommendations

- A low delivery rate may indicate incorrect recipient details or email delivery problems.
- A high open rate shows that many recipients viewed the message, but does not prove they were deceived.
- A high click rate indicates that the message or link attracted attention and that additional awareness training may be useful.
- Any accidental disclosure of real credentials should trigger immediate incident handling.

Recommended improvements include:

1. Conduct recurring phishing-awareness training.
2. Teach employees to inspect sender addresses and URLs.
3. Enable MFA, preferably phishing-resistant methods.
4. Configure SPF, DKIM, and DMARC.
5. Provide a one-click phishing-reporting method.
6. Use email filtering and endpoint protection.
7. Give supportive, non-punitive feedback after simulations.
8. Repeat simulations and compare results over time.

Screenshots to include

Recently, I learned how to use Gophish, an open source tool for creating and launching phishing campaigns! While setting it up, I ran into an issue that prevented me from connecting to the phishing… | Ihsan E.

Screenshot 1 – Campaign dashboard

Show the campaign name, status, and actual event counts.

§ Gophish - Implementing a Real-World Phishing Exercise to Teach Social Engineering | Cybersecurity Research

Screenshot 2 – Campaign metrics

Show delivery, open, and click events from the completed lab campaign.

Result

The GoPhish simulation provides measurable information about employee interactions with a training email. These metrics can guide awareness training and improvements to email security. Actual results must be taken from the completed lab campaign.

3. Nmap Aggressive Scan and Social Engineering Risk Analysis (10 Marks)

Aim

To perform an authorized Nmap scan of `scanme.nmap.org`, review detected ports and services, and explain how technical information could contribute to social-engineering risks and how organizations can defend against them.

Tool required

Nmap in Kali Linux.

Step 1: Check Nmap installation

```
nmap --version
```

Step 2: Perform the scan

The host `scanme.nmap.org` is provided by the Nmap project for testing Nmap. Keep scans within its published usage policy.

```
nmap -A scanme.nmap.org
```

The `-A` option enables several detection features, including:

- OS detection
- Service and version detection
- Default NSE script scanning
- Traceroute

Aggressive scanning is more intrusive than a basic port scan, so use it only where permitted.

Step 3: Analyze the output

Record the results that Nmap actually returns.

Information	Security relevance
Open ports	Indicates which network services are reachable
Service versions	Helps administrators identify outdated or unsupported software
OS detection	May help identify operating-system-specific security requirements
Script results	May reveal configuration details or potential security concerns
Traceroute	May provide information about the network path

OS and version detection are estimates and may not always be accurate.

How technical information can increase social-engineering risk

An attacker might combine publicly available technical information with organizational details to make fraudulent communications more convincing. For example:

1. Technology-based pretexts: Misuse knowledge of software or systems to make a fake technical-support request sound credible.
2. False security alerts: Claim that an employee's system needs an urgent update or security check.
3. Impersonation: Pretend to be a support engineer or IT administrator.
4. Credential theft attempts: Direct employees to fraudulent login pages under the pretext of fixing a technical problem.
5. Targeted communication: Use publicly available employee roles and organizational information to personalize fraudulent messages.

These are threat scenarios, not proof that the scanned host is vulnerable. Avoid contacting real IT staff with deceptive messages; any social-engineering simulation should use approved participants and dummy accounts.

Defensive recommendations

1. Keep operating systems and network services updated.
2. Close unnecessary ports and restrict administrative services using firewall rules.
3. Apply least-privilege access controls.
4. Require MFA for remote access and privileged accounts.
5. Train IT support teams to verify identities before resetting passwords or changing access permissions.
6. Establish a formal process for approving software updates and urgent security requests.
7. Monitor network traffic and logs for unusual connections.
8. Conduct regular authorized vulnerability assessments.
9. Use email filtering and phishing-resistant authentication to reduce credential theft.
10. Document and respond to suspected social-engineering incidents promptly.

Screenshots to include

devilslab.in

Screenshot 1 – Nmap command

Capture the command and the actual output from your terminal.

What is Nmap?. What is Nmap? What is Nmap? Nmap is a… | by ibrahim atasoy | Medium

Screenshot 2 – Scan findings

Show detected ports, services, versions, and OS-detection results, if available.

Result

Nmap's aggressive scan can help identify exposed services and gather technical information for security assessment. Such information should be used to prioritize patching, reduce unnecessary exposure, and strengthen defenses against targeted social engineering.

Final submission checklist

Practical report checklist

0 of 6

- [ ] Include the aim and tools for each experiment
- [ ] Capture genuine screenshots from Kali Linux and GoPhish

- [ ] Record actual scan results and campaign metrics
- [ ] Separate observed findings from hypothetical examples
- [ ] Include risk analysis and at least five countermeasures
- [ ] Ensure all testing and simulations remain authorized